COMPTIA PENTEST+ PT0-003 · DOMAIN 3.0

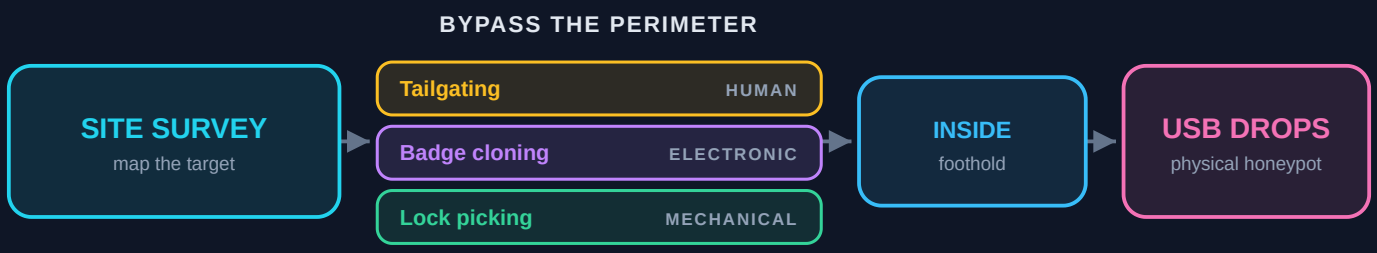
Domain 3.3 — Physical Security Concepts

The five physical techniques a tester uses to get into a building and turn that access into compromise — and the controls that stop each one. Read as a kill-chain: recon, bypass, foothold.

Objective 3.3 — Explain physical security concepts. Tailgating · Site surveys · USB drops · Badge cloning · Lock picking

MAP The physical penetration test kill-chain

Physical tests rarely use one technique in isolation. The site survey feeds everything; a perimeter bypass (human, electronic, or mechanical) gets you inside; once inside, USB drops convert physical access into code execution. Cards below are colored by bypass vector.



Recon enables every bypass; a bypass gets you inside; inside, USB drops turn access into code execution.

RECON Map the facility first. Everything downstream depends on it. **HUMAN** Beat the person, not the technology.

ELECTRONIC Defeat the credential technology itself. **MECHANICAL** Defeat the physical barrier — covertly.

PAYLOAD Turn physical access into code execution.

1 Concept cards

Color-railed by vector. Exam tells are woven into each card, not bolted on at the end.

Site survey

RECON THE FIRST STEP

The reconnaissance phase of a physical penetration test: a structured walk of the facility's security posture from the outer perimeter to the innermost secured areas, answering 'how is this protected, and where are the gaps?'

It is the prerequisite for every other physical technique — it tells you which doors are tailgate-able, what badge tech is in use, which locks you'd face, where cameras don't cover, and how employees behave.

- The FIRST step of a physical pentest — it precedes and enables everything else.
- Identifies physical controls AND their weaknesses, layer by layer.
- Uses passive methods (satellite / Google Earth) and active ones (on-site walk, photography, surveillance).
- Surveillance of behavioral patterns (arrivals, patrols, deliveries) is a key component.
- Documentation — an annotated map + prioritized weaknesses — is a required output.

EXAM TELL If a stem asks for the FIRST step of a physical pen test, it's the site survey. Walking a facility photographing cameras / entry points / observing employees = site survey.

Tailgating

HUMAN SOCIAL BYPASS

Following an authorized person through a secured door without independently authenticating — exploiting the gap between the door opening and closing. No tools, no tech; it exploits social courtesy and weak enforcement culture.

The exam-critical twin is piggybacking: same physical result, but the authorized person KNOWINGLY helps (holds the door) versus tailgating, where they're UNAWARE.

- Tailgating = the authorized person is UNAWARE. Piggybacking = they KNOWINGLY help.
- Best countermeasure = security vestibule / mantrap (only ONE door opens at a time).
- Works because of social norms, visual blending, busy entrances, slow-closing doors, weak enforcement.
- Often paired with pretexting (delivery driver, IT, contractor) to avoid being challenged.
- Bypasses the access-control system without defeating the technology.

EXAM TELL 'Followed an employee through a secured door without them noticing' = tailgating. 'Which control BEST prevents it' = security vestibule / mantrap. Distinguish from piggybacking by AWARENESS.

Badge cloning

ELECTRONIC

COPY THE CREDENTIAL

Reading the data off an access credential (RFID, prox, or magnetic-stripe card) and writing it to a blank to make an exact duplicate the reader accepts as genuine. This defeats the credential TECHNOLOGY itself.

Its defining danger is that it leaves NO evidence: the original keeps working, so the victim never knows their credential was copied — unlike a stolen badge, which is missed.

- Leaves NO evidence — the original still works; the key danger characteristic.
- Most vulnerable: magnetic stripe (plaintext) and low-frequency 125 kHz RFID (broadcasts its ID openly).
- Most resistant: smart cards — IF properly implemented (challenge-response + PIN). The qualifier matters.
- Best countermeasure: multi-factor at the door (badge + PIN) — a cloned badge alone becomes useless.
- RFID can be read at a distance (proximity) in an elevator/lobby without the cardholder knowing.

EXAM TELL 'A device was held near an employee's badge in an elevator' or 'a blank card was programmed to open the same doors' = badge cloning. 'Most resistant' = smart card; 'most vulnerable' = mag stripe / LF RFID; 'why so dangerous' = no evidence.

Lock picking

MECHANICAL

BEAT THE BARRIER

Manipulating a lock's internal pins to open it without the key, exploiting the tiny manufacturing misalignments in a pin tumbler lock. Done right it leaves no evidence and the lock still works afterward.

It needs two tools working together — a tension wrench (applies rotational pressure so pins bind and set at the shear line) and a pick. It's one of several mechanical-bypass options, and it is legally sensitive.

- Requires a tension wrench AND pick tools; targets pin tumbler locks (bind pins to the shear line).
- Leaves NO evidence of entry — the lock relocks and looks untouched.
- SPP (single pin picking) = methodical, works on high-security; raking = fast but less precise.
- Alternatives: bump keys (strike to bounce all pins), shimming (padlock shackle), impressioning (marks on a blank -> file a working key), destructive entry (obvious, last resort).
- WRITTEN AUTHORIZATION is required; lock-pick possession laws vary by jurisdiction ('burglary tools').

EXAM TELL 'Opened a server-room door without a key and without damaging the lock' = lock picking. Tools = tension wrench + picks. A key struck with a mallet = bump key. Legal angle = written authorization.

USB drops

PAYLOAD | PHYSICAL HONEYPOT

Placing malicious USB drives where employees will find them (parking lot, lobby, break room) and letting human curiosity do the rest — when someone plugs it in, the payload runs. The attacker never has to enter the building.

In an engagement it is a dual test: of technical endpoint controls (port blocking, autorun, EDR) AND of employee security awareness at the same time.

- Exploits human curiosity + misplaced trust — the core vulnerability.
- Known on the exam as a 'physical honeypot'.
- Tests BOTH technical endpoint security AND human awareness simultaneously.
- Placement matters: parking lots, lobbies, break rooms, near printers.
- HID emulator payload = the drive acts as a keyboard ('Rubber Ducky').
- Countermeasures: disable USB ports / device whitelisting (technical) + awareness training (human).
- Requires no building entry — begins with a purely physical act (placing the drive).

EXAM TELL 'USB drives left in the parking lot / break room' = USB drop. Alt term = 'physical honeypot'. Effective because of curiosity; it tests technical AND human controls.

Credential vulnerability ladder

ELECTRONIC

RANK THE TECH

Badge cloning viability is entirely about which credential technology the target uses. From easiest to hardest to clone: magnetic stripe (plaintext, trivially copied) < low-frequency 125 kHz RFID (broadcasts an unencrypted ID) < high-frequency 13.56 MHz RFID (MIFARE Classic / iCLASS — may add crypto but often weak/default keys) < smart card (cryptographic challenge-response + PIN).

- Mag stripe = oldest, no security, plaintext — most vulnerable.
- LF 125 kHz RFID = openly broadcasts its ID — extremely easy, still widely deployed.
- HF 13.56 MHz RFID = sometimes encrypted, but weak/default keys often break it.
- Smart card = strongest, resistant IF properly implemented.
- Most orgs still run older, cloneable tech — which is why cloning stays viable.

EXAM TELL Rank questions: 'most vulnerable' = mag stripe / LF RFID; 'most resistant' = smart card (watch for the 'properly implemented' qualifier).

The lock-bypass family

MECHANICAL

NOT JUST PICKING

Picking is one of several ways testers defeat a lock. Know the siblings by their tell: shimming slips a shim past a padlock shackle; a bump key is struck to momentarily bounce all pins above the shear line; impressioning works a blank under tension until the pin marks let you file a working key; destructive entry (drill/cut) is obvious and a last resort; key duplication copies an existing key.

- Bump key = a specially cut key STRUCK with a mallet to bounce pins.
- Shimming = defeats lower-quality padlocks via the shackle pawl.
- Impressioning = produces an actual working key from marks on a blank.
- Destructive entry = leaves evidence; only when covert entry isn't required.
- Picking, bumping, shimming, impressioning are all covert (no/low evidence).

EXAM TELL Distinguish the family: 'key struck to bounce the pins' = bump key; 'filed a blank into a working key' = impressioning; 'shim past a padlock shackle' = shimming.

Authorization & legal footing

RECON

CROSS-CUTTING

Every physical technique here — site survey, tailgating, badge cloning, lock picking, USB drops — requires explicit WRITTEN authorization in the scope of work. Physical pentesting mirrors burglary; without paperwork it is simply crime.

Lock picking carries an extra wrinkle: possession of lock picks is restricted or outlawed in some jurisdictions ('burglary tools'), so verify local law before carrying them.

- ALL physical techniques require explicit written authorization in the SoW.
- Without authorization, these actions are criminal — not merely unethical.
- Lock-pick possession laws vary by jurisdiction; check before carrying tools.
- Testers document what they attempted and whether they were challenged/detected.

EXAM TELL Any 'is this allowed / what's required first' physical question points to written authorization. Lock-pick legality varies by jurisdiction is a favorite legal-nuance item.

2 Critical comparisons

The blurred pairs this objective loves. Read the verdict line last — it's the tie-breaker.

Tailgating vs Piggybacking

Tailgating

Unauthorized person slips in behind an authorized one WITHOUT their awareness. Silent; relies on inattention and slow-closing doors.

vs

Piggybacking

The authorized person KNOWINGLY holds the door (social pretext — hands full, badge trouble). Relies on courtesy overriding policy.

▸ The discriminator is AWARENESS. A security vestibule (mantrap) stops both, because only one door opens per authentication.

Tailgating vs Badge cloning

Tailgating (bypass)

Walks around the access-control tech entirely by exploiting a person. The badge system is never defeated — it's sidestepped.

vs

Badge cloning (defeat)

Attacks the credential technology itself, producing a duplicate the reader accepts. The system is beaten on its own terms.

▸ 'Bypasses access control WITHOUT defeating the technology' = tailgating. 'Defeats the technology itself' = badge cloning.

Tailgating vs Lock picking

Tailgating

For MANNED or badge-controlled entrances where human/social behavior is the weakness. No mechanical work.

vs

Lock picking

For UNMANNED, mechanically locked doors where there's no person to exploit. Pure mechanical bypass.

▸ Different barrier types. They chain: tailgate into the building, then pick the server-room lock.

Badge cloning vs Badge theft

Cloning

Copies the credential and leaves the original intact and working. Victim has NO indication of compromise.

vs

Theft

Removes the badge — the victim notices it's gone and it can be revoked.

▸ Cloning's signature danger is 'no evidence' — the original still works, so nothing looks wrong.

Mag stripe / LF RFID vs Smart card

Mag stripe / LF 125 kHz RFID

Plaintext or openly broadcast ID. Cheap gear clones them; widely deployed despite known weakness.

vs

Smart card

Cryptographic challenge-response + PIN. Resistant to cloning — IF properly implemented.

▸ Vulnerability ladder: mag stripe / LF RFID are most vulnerable; the smart card is most resistant (mind the 'properly implemented' qualifier).

Single pin picking vs Raking

Single pin picking (SPP)
Sets one binding pin at a time. Methodical, high control; works on high-security locks.

vs

Raking
Rapidly bounces multiple pins at once. Fast but imprecise; best on lower-quality locks.

▸ Control vs speed. SPP for tight-tolerance/high-security locks; raking for quick wins on cheap locks.

Lock picking vs Destructive entry

Lock picking
Covert — the lock relocks and shows no sign of entry. Preferred for stealth assessments.

vs

Destructive entry
Drilling/cutting/breaking. Obvious, leaves evidence — a last resort when covert entry isn't required.

▸ Picking is covert; destructive entry announces itself. Choose by whether the test must stay undetected.

USB drop vs Phishing

USB drop
Begins with a PHYSICAL act — placing a device — then rides human curiosity. Categorized under physical security.

vs

Phishing
A purely digital lure delivered over email/web. No physical component.

▸ A USB drop is grouped under physical security because the attack starts by physically placing the drive (a 'physical honeypot').

3 Scenario decoder

Stem clue → the technique it points to. These phrasings recur almost verbatim on the exam.

An attacker followed an employee through a secured door without the employee noticing	→	HUMAN **Tailgating**
An employee held the door open for someone claiming their hands were full	→	HUMAN **Piggybacking**
Which control BEST prevents tailgating?	→	HUMAN **Security vestibule / mantrap (one door at a time)**
A tester walked the facility photographing camera positions and entry points	→	RECON **Site survey**

What is the FIRST step of a physical penetration test?	→	RECON **Site survey**
USB drives were left in the company parking lot	→	PAYLOAD **USB drop**
USB drives were left in the break room near the coffee machine	→	PAYLOAD **USB drop**
What is a USB drop also called on the exam?	→	PAYLOAD **Physical honeypot**
A device was held near an employee's badge in an elevator	→	ELECTRONIC **Badge cloning**
A blank card was programmed to open the same doors as an employee's badge	→	ELECTRONIC **Badge cloning**
Which credential is MOST resistant to cloning?	→	ELECTRONIC **Smart card (properly implemented)**
Which credentials are MOST vulnerable to cloning?	→	ELECTRONIC **Magnetic stripe / low-frequency 125 kHz RFID**
Why is badge cloning particularly dangerous?	→	ELECTRONIC **It leaves no evidence — the original still works**
A tester used a tension wrench and pick to open a server-room door	→	MECHANICAL **Lock picking**
Entry was gained to a secured area without damaging the lock and without a key	→	MECHANICAL **Lock picking**
A specially cut key was struck with a mallet to bounce the pins	→	MECHANICAL **Bump key**
A blank key was filed into a working key using marks left under tension	→	MECHANICAL **Impressioning**
What is legally required before any lock picking on an engagement?	→	MECHANICAL **Written authorization**

4 Practice quiz

Sixteen scenario-style items. Answer in your head, then reveal the key and the reasoning — the explanation is the point, not the score.

Q1 An unauthorized person slips through a secured door right behind an employee who never realizes anyone followed. Which technique is this?

A Piggybacking

B Tailgating

C Badge cloning

D Impersonation

ANSWER **B · Tailgating**

Following through a secured door WITHOUT the authorized person's awareness is tailgating. Piggybacking is when the authorized person knowingly holds the door.

Q2 An employee, seeing a person carrying boxes, holds the secured door open for them. This is BEST described as:

A Tailgating

B Shoulder surfing

C Piggybacking

D Site survey

ANSWER **C · Piggybacking**

When the authorized person KNOWINGLY allows entry (out of courtesy/social pressure), it's piggybacking. The awareness of the authorized person is the discriminator.

Q3 Which control most effectively prevents both tailgating and piggybacking?

- A A security guard
- B A security vestibule (mantrap)
- C Video surveillance
- D Badge readers

ANSWER **B · A security vestibule (mantrap)**

A security vestibule/mantrap allows only one door to open at a time, forcing independent authentication and physically preventing a second person from slipping through.

Q4 A penetration tester walks the perimeter, photographs camera placements and entry points, and observes when employees arrive. This activity is:

- A A USB drop
- B A site survey
- C Badge cloning
- D Tailgating

ANSWER **B · A site survey**

Systematically observing and documenting the facility's physical security posture is the site survey — the reconnaissance phase and first step of a physical pentest.

Q5 Which technique is typically the FIRST step of a physical penetration test?

- A Lock picking
- B Badge cloning
- C Site survey
- D USB drop

ANSWER **C · Site survey**

The site survey comes first; it identifies controls and weaknesses and informs every subsequent physical technique.

Q6 USB drives loaded with a payload are scattered in a target's parking lot and break room. This attack is also known on the exam as a:

A Watering hole

B Physical honeypot

C Rubber ducky

D Evil twin

ANSWER **B · Physical honeypot**

A USB drop is described as a 'physical honeypot' — it lures curious employees into plugging in a malicious device. (A Rubber Ducky is a specific HID-emulator payload, not the attack's name.)

Q7 What is the PRIMARY human vulnerability a USB drop attack exploits?

A Greed

B Curiosity

C Fear

D Authority bias

ANSWER **B · Curiosity**

USB drops rely on human curiosity (and misplaced trust in a found object) — people plug in the drive to see what's on it.

Q8 In a penetration test, a USB drop simultaneously tests:

A Only endpoint antivirus

B Only physical door security

C Both technical endpoint controls AND employee awareness

D Only network segmentation

ANSWER **C · Both technical endpoint controls AND employee awareness**

A USB drop is a dual test: whether endpoint controls (port blocking, autorun, EDR) stop the payload, and whether employees are trained to not plug in unknown drives.

Q9 An attacker holds a concealed reader near an employee's badge in a crowded elevator, then writes the captured data to a blank card. This is:

A Tailgating

B Badge cloning

C Shimming

D Impressioning

ANSWER **B · Badge cloning**

Reading a credential's data and writing it to a blank to make a working duplicate is badge cloning — here via proximity capture at close range.

Q10 Why is badge cloning considered particularly dangerous?

A It destroys the original badge

B It triggers an alarm

C It leaves no evidence of compromise

D It only works once

ANSWER **C · It leaves no evidence of compromise**

Cloning leaves the original intact and working, so the victim has no indication their credential was copied — unlike theft, which is noticed.

Q11 Which access-credential technology is MOST resistant to cloning when properly implemented?

A Magnetic stripe

B Low-frequency 125 kHz RFID

C Smart card

D Proximity card

ANSWER **C · Smart card**

Smart cards use cryptographic challenge-response plus a PIN, making them the most resistant — but only if properly implemented (the qualifier matters).

Q12 Which technologies are MOST vulnerable to cloning?

A Smart cards and biometrics

B Magnetic stripe and low-frequency 125 kHz RFID

C 13.56 MHz encrypted cards only

D None can be cloned

ANSWER **B · Magnetic stripe and low-frequency 125 kHz RFID**

Magnetic stripe stores plaintext data and LF 125 kHz RFID openly broadcasts an unencrypted ID; both are trivially copied with inexpensive gear.

Q13 Which countermeasure most reduces the value of a cloned badge?

A Longer badge numbers

B Multi-factor authentication at the door (badge + PIN)

C Brighter lobby lighting

D Painting the badges

ANSWER **B · Multi-factor authentication at the door (badge + PIN)**

Requiring a badge AND a PIN means a cloned badge alone can't open the door, neutralizing the clone.

Q14 A tester opens a locked server-room door using a tension wrench and a pick, leaving the lock undamaged. The technique is:

A Shimming

B Lock picking

C Destructive entry

D Bump key

ANSWER **B · Lock picking**

Manipulating pins to the shear line with a tension wrench and pick, without damage, is lock picking. Shimming targets padlock shackles; a bump key is struck, not raked.

Q15 A specially cut key is inserted and struck sharply with a mallet to momentarily bounce all pins above the shear line. This is a:

- A Rake
- B Bump key
- C Shim
- D Impression

ANSWER **B · Bump key**

That's a bump key — the impact bounces the pins so the plug can be turned at that instant. Raking uses a pick moved rapidly; impressioning files a blank into a working key.

Q16 Before a tester may pick locks during an engagement, what is essential?

- A A backup lock
- B Written authorization in the scope of work
- C A destructive-entry plan
- D A spare key

ANSWER **B · Written authorization in the scope of work**

Written authorization is required — without it, lock picking is criminal. Note also that lock-pick possession laws vary by jurisdiction.

5 Keyword table

Every term dotted to its vector. Use the search box up top to filter.

Site survey	Reconnaissance phase; the first step of a physical pentest.
Reconnaissance	Information gathering before active physical testing.
Surveillance	Extended observation of behavioral patterns (arrivals, patrols, deliveries).
Written authorization	Legally required before ANY physical technique; SoW paperwork.
Tailgating	Following an authorized person through a door WITHOUT their awareness.

Piggybacking	Authorized person KNOWINGLY holds the door for the intruder.
Security vestibule / mantrap	Best anti-tailgating control — only one door opens at a time.
Pretexting	Cover story (delivery, IT, contractor) to avoid being challenged.
Social norms	Courtesy/conflict-avoidance — why tailgating works.
Badge cloning	Copying a credential to a blank card; leaves no evidence.
Magnetic stripe	Plaintext data — most vulnerable credential type.
Low-frequency RFID (125 kHz)	Broadcasts an unencrypted ID — easily cloned, widely deployed.
High-frequency RFID (13.56 MHz)	MIFARE/iCLASS; may add crypto but weak/default keys often break it.
Smart card	Challenge-response + PIN — most resistant IF properly implemented.
Multi-factor at the door	Badge + PIN — best countermeasure to a cloned badge.
No evidence	Cloning's key danger — original still works, victim unaware.
Lock picking	Manipulating pin tumbler internals open without a key; no evidence.
Tension wrench	Applies rotational pressure so pins bind and set at the shear line.
Pin tumbler lock	Most common lock type and primary pick target.
Shear line	Plug/housing boundary pins must align with to turn.
Single pin picking (SPP)	Methodical, one pin at a time; works on high-security locks.
Raking	Rapid, imprecise picking; best on low-quality locks.
Bump key	A cut key STRUCK to momentarily bounce all pins.
Shimming	Slips a shim past a padlock shackle pawl.
Impressioning	Files a blank into a working key from pin marks.
USB drop	Placing malicious USB drives for curious employees to find.
Physical honeypot	Exam's alternative name for a USB drop.
Human curiosity	The core vulnerability a USB drop exploits.
HID emulator / Rubber Ducky	USB payload that acts as a keyboard typing commands.
Endpoint control / awareness training	Technical + human countermeasures to USB drops.

6 Exam strategy — the night-before strip

- Tailgating vs piggybacking = AWARENESS. Tailgating: the authorized person is unaware. Piggybacking: they knowingly help. A security vestibule (mantrap) stops both.
- The site survey is always the FIRST step and it informs every other physical technique — expect sequencing questions.
- USB drop = 'physical honeypot'; it exploits curiosity and tests technical controls AND employee awareness at once.
- Badge cloning's signature is 'no evidence'. Mag stripe / LF RFID are most vulnerable; smart cards most resistant (if properly implemented); MFA at the door is the best countermeasure.
- Lock picking needs a tension wrench AND picks, leaves no evidence, and REQUIRES written authorization — pick-possession laws vary by jurisdiction.
- Bypass vs defeat: tailgating bypasses access control without beating the tech; badge cloning defeats the tech itself.
- Security vestibule works because only ONE door opens at a time — that mechanic is the answer to 'why does it prevent tailgating'.
- Every physical technique — survey, tailgate, clone, pick, USB drop — requires explicit written authorization in scope.

Built to the official PT0-003 v3.0 objective 3.3 sub-bullets. Not affiliated with or endorsed by CompTIA.